

SEC102

MENACES INFORMATIQUES ET CODES MALVEILLANTS
ANALYSE ET LUTTE

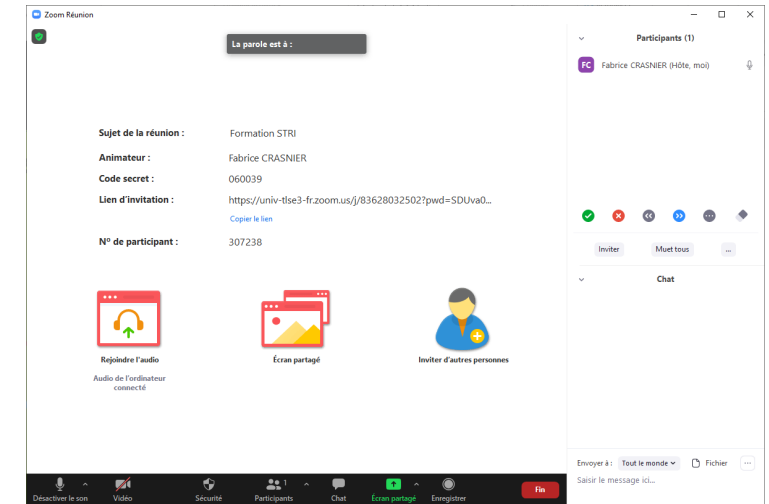
2

Bienvenue sur la formation en ligne via Zoom

Coordonnées de la salle ZOOM

Fabrice CRASNIER vous invite à une réunion Zoom planifiée.

Sujet : Cours CNAM SEC102



Participer à la réunion Zoom

<https://univ-tlse3-fr.zoom.us/j/91611860094?pwd=K3YwNHbZb3UyYmJMbm9oTXBRdy9WZz09>

ID de réunion : 916 1186 0094

Code secret : 687038



Equipe pédagogique SEC102



Fabrice CRASNIER, enseignant FSI à UT3 en M2 SSIR/STRI/ISSD, expert de justice près la Cour d'Appel de Toulouse, dirigeant SASU CyberFabLab expertises et formations
tel : 06.24.49.39.20,
mail : fabrice.crasnier@cyberfablab.fr



Anthony DESSIATNIKOFF, vacataire M2 SSIR, dirigeant de CodiTrust tests d'intrusion et Formateur cybersécurité,
tel : 06.31.57.30.75,
mail : anthony@coditrust.com,
Site web : <https://www.coditrust.com>.



Félix Guyard, dirigeant de forensicXlab, tel : 06.82.82.16.68,
mail : felix.guyard@forensicxlab.com,
twitter : @k1nd0ne,
site web : <https://www.forensicxlab.com/>

4

Calendrier prévisionnel de la formation

Cours	Date	Titre du cours	Enseignant
08	mer 10/05/2023 (sem 19)	Analyse mémoire.	Félix GUYARD
09	lun 15/05/2023 (sem 20)	L'analyse forensic post mortem	Fabrice CRASNIER
10	Mer 24/05/2023 (sem 21)	Développer un plan de remédiation après un incident de sécurité.	Félix GUYARD
11	Mar. 30/05/2023 (sem 22)	Rédaction du rapport de réponse sur incident, la conservation des preuves,	Fabrice CRASNIER
12	lun. 05/06/2023 (sem.23)	Présentation des audits de sécurité	Anthony DESSIATNIKOFF
13	lun. 12/06/2023 (sem.24)	Introduction au langage Python appliqué à cybersécurité	Anthony DESSIATNIKOFF
14	lun. 19/06/2023 (sem.25)	RGPD, préparation d'un dossier de plainte, poursuite vers une juridiction	Fabrice CRASNIER

MENACES INFORMATIQUES ET CODES MALVEILLANTS ANALYSE ET LUTTE

Développer un plan de remédiation après un
incident de sécurité

6 Sommaire

- Définitions.
- Les étapes clés de la remédiation.
- Les acteurs clés de la remédiation.
- Étude de cas : Compromission par un rançongiciel sans PCA/PRA.
- Mise en pratique : Automatisation de la recherche de compromission avec FastFind - DFIR ORC (TD/TP).

7 Définitions

Plan de remédiation : Ensemble de procédures et d'actions à mettre en œuvre pour contenir, évaluer et neutraliser les conséquences d'un incident de sécurité.

Plan de continuité d'activités (PCA) : ensemble de procédures et de stratégies préparées à l'avance pour permettre à une entreprise ou à une organisation de continuer à fonctionner en cas d'incident majeur ou de catastrophe.

Plan de reprise d'activités (PRA) : Processus documenté qui décrit la façon dont une organisation peut récupérer et restaurer les données, les systèmes et les applications critiques après une interruption d'activité due à une catastrophe, une panne de système ou une autre perturbation.

Le processus de remédiation commence dès le début d'une réponse à incident.

8

Les différentes étapes de la remédiation

1. Identification et élimination de la cause racine.

- Mener les enquêtes nécessaires afin d'identifier le point d'entrée de l'attaque et être en mesure de la contenir.
- Utiliser toutes les méthodes d'investigation permettant l'identification de la cause (analyse réseau, système, mémoire,...)
- Cette phase étape est à effectuer **le plus rapidement possible**.
- **Documenter les actions effectuées (rapport d'investigation, photos, procédures suivie, méthodologie d'investigation...)**

2. Analyse des impacts

- Déterminer l'étendue des dommages (périmètre de compromission)
- Déterminer une liste de priorités pour la reprise ou la continuité de l'activité.

Les différentes étapes de la remédiation

3. Prise de mesures correctives

- On veut empêcher que l'incident de se reproduire.
- Revoir les politiques et les procédures actuelles (PCA/PRA/Active directory, cloisonnement réseau, etc...)
- Lister les mesures corrective faciles à implémenter permettant une augmentation rapide du niveau de sécurité.

4. Restauration des systèmes

- Déterminer les systèmes endommagés/compromis pendant l'incident de sécurité. (FastFind)
- Restaurer les systèmes à un état de fonctionnement acceptable. **PRA**
- Appliquer les mesures sur les composants clés du système d'information (Active directory, pare-feux, etc..)

5. Formation et sensibilisation

- Former les employés sur les mesures de sécurité appropriées afin de prévenir les incidents à l'avenir.

6. Suivi et évaluation

- Suivre et d'évaluer régulièrement les politiques et les procédures pour s'assurer qu'elles sont toujours efficaces et qu'elles répondent aux besoins de l'entreprise (audits de sécurité, ...).

11

Les acteurs clés de la remédiation

L'équipe de réponse à l'incident

- Responsable de la gestion de l'incident et de la coordination de la remédiation.

Les administrateurs système et réseaux

- responsables de la mise en place des correctifs de sécurité, de la configuration des pare-feux et de la surveillance des systèmes.

Les équipes de développement

- responsables de la correction des vulnérabilités dans les applications et les logiciels.

12

Les acteurs clés de la remédiation

Les employés

- Ils doivent être conscients des menaces potentielles et des bonnes pratiques en matière de sécurité informatique pour éviter de compromettre la sécurité de l'entreprise.
- Ils sont aussi une source d'information très importante pour l'investigation.

Les fournisseurs de services de sécurité

- Peuvent fournir des solutions de sécurité supplémentaires pour renforcer la sécurité de l'entreprise.

Les autorités réglementaires

- Elles peuvent être impliquées dans les incidents majeurs de cybersécurité pour enquêter sur la violation de la loi et veiller à ce que l'entreprise soit conforme aux réglementations en matière de sécurité.

13

Étude de cas réel : Compromission par un rançongiciel sans PCA/PRA.

Contexte : Compromission d'une entreprise du CAC40 par le rançongiciel Ryuk.

- Les serveurs de sauvegardes ont été chiffré.
- Le RSSI vient de prendre ces fonctions et le PCA et le PRA prévus n'ont pas pu être mis en œuvre.

+ 300 machines chiffrée, +10 contrôleurs de domaines compromis et chiffrés.

Conclusion: **Tout est à reconstruire.**

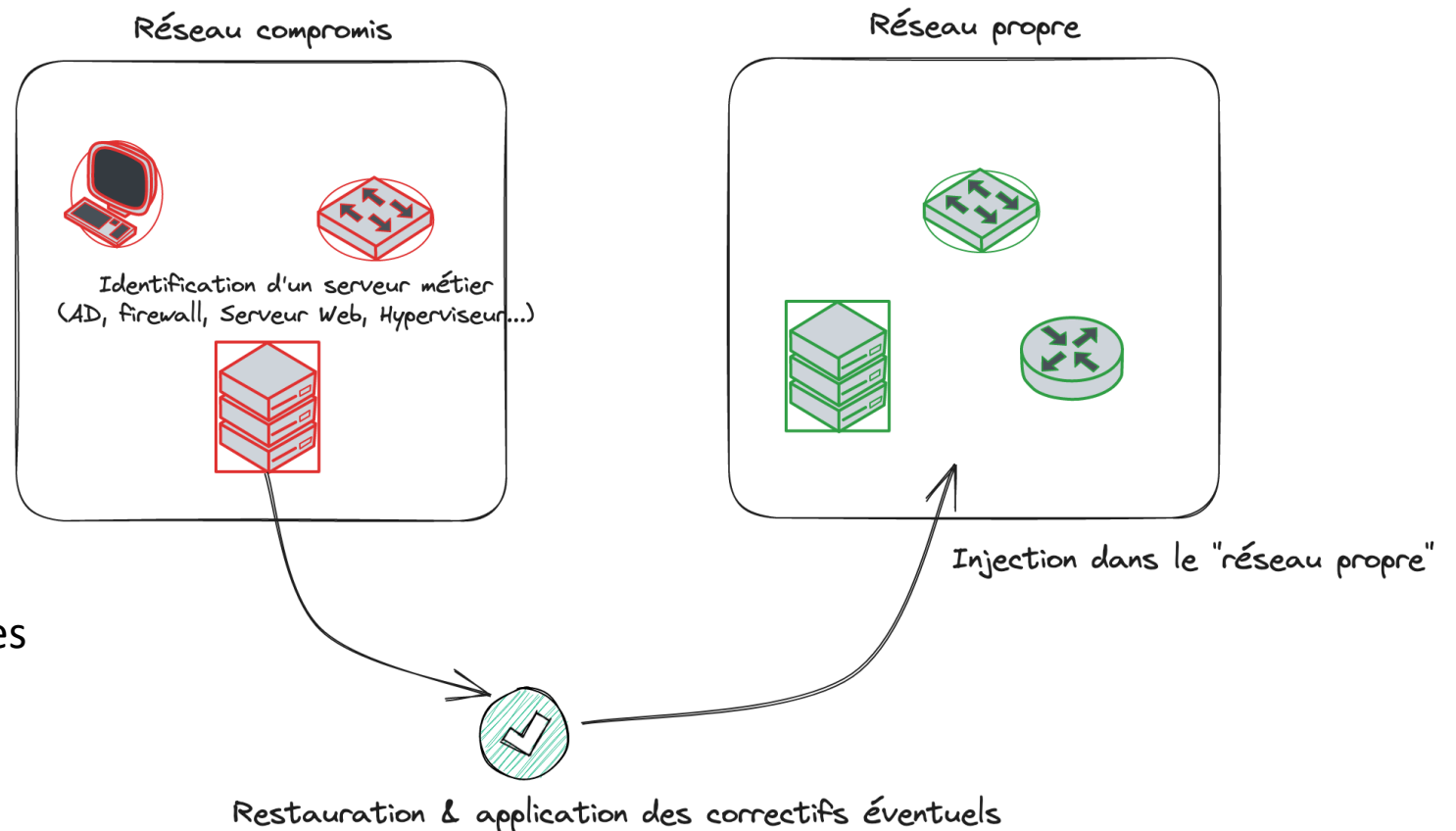
Les employés ne peuvent plus travailler.

14

Étude de cas : Compromission par un rançongiciel sans PCA/PRA.

Méthodologie de remédiation.

- Participation de l'ensemble des acteurs.
- Les employés ont repris le travail 2 semaines après l'incident en mode dégradé
- Durée totale de la remédiation : 3 mois



Étude de cas : Compromission par un rançongiciel sans PCA/PRA.

Les grands axes de remédiation :

1.Sécurité des comptes : pour limiter les possibilités de latéralisation sur le système d'information, des comptes spécifiques doivent être mis en place pour chaque type d'usage (comptes d'administrations des serveurs critiques, d'administrations des serveurs classiques, d'administrations des postes de travail et comptes utilisateurs). Une politique de mot de passe adéquate doit être définie afin de s'assurer que les mots de passes utilisés soient forts et modifiés de manière régulière. Aussi, un **modèle par tiering** est nécessaire, pour protéger les comptes critiques comme les comptes d'administrateurs de domaine.

2.Accès au système d'information : il est nécessaire de mettre en place des solutions permettant de sécuriser les accès au système d'information de l'entité permettant d'authentifier de manière forte les utilisateurs et de bloquer la plupart des attaques par énumération.

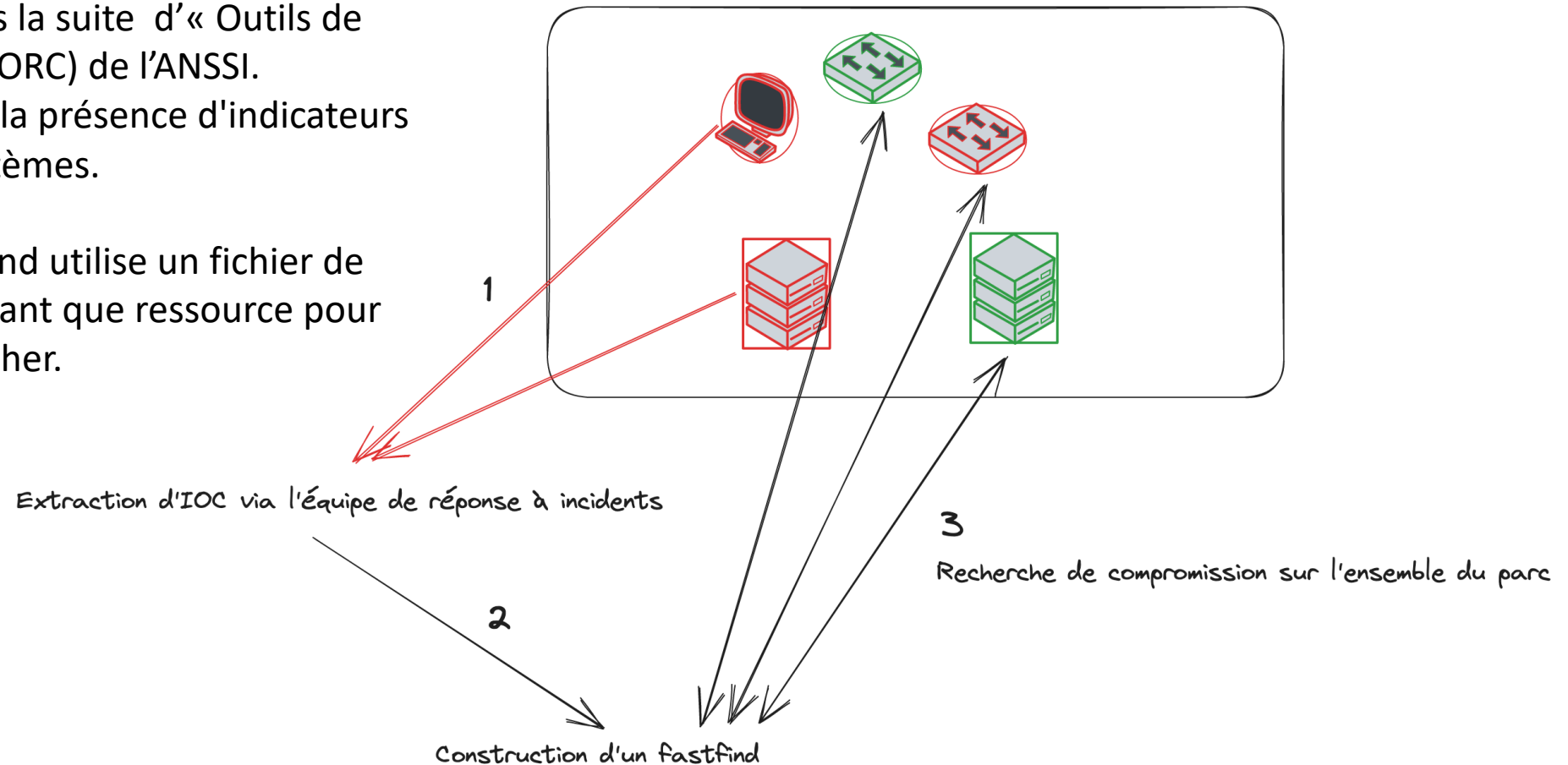
3.Sécurité des sauvegardes : Bien que client possède des sauvegardes externalisées qui ont permis de diminuer l'impact de la cyber-attaque, il faudra conserver une routine de sauvegardes récurrentes et conserver une copie déconnectée du réseau afin de les mettre hors de portée des adversaires.

16

Automatisation de la recherche de compromission avec FastFind - DFIR ORC

FastFind est un outil présent dans la suite d'« Outils de Recherche de Compromission » (ORC) de l'ANSSI.
Le but de FastFind est de vérifier la présence d'indicateurs connus sur de des milliers de systèmes.

Pour atteindre cet objectif, FastFind utilise un fichier de configuration XML incorporé en tant que ressource pour spécifier les indicateurs à rechercher.



La qualité de la remédiation, dépend de la qualité de la phase d'investigation de la réponse à incident et des recommandations générées.

La remédiation nécessite des compétences multiples (technique, juridique, organisationnel, ...) et un sens du relationnel important.

L'éducation passe par la remédiation, il est nécessaire de prévoir avec soin une possible réponse à incident (PCA, PRA, Centralisation des journaux, bonnes pratiques, tests réguliers).

Les outils d'investigations sont de plus en plus performants et spécialisés pour la réponse à incidents -> Remédiation plus rapide.

18

Ressources utiles

Mesures de sécurité Windows : <https://mpy.moodle.lecnam.net/mod/resource/view.php?id=49107>

Mesures de sécurité Linux : <https://github.com/imthenachoman/How-To-Secure-A-Linux-Server>

DFIR ORC : <https://dfir-orc.github.io/>

En piste ! C'est l'heure de la partie pratique.

- Télécharger le TD sur moodle : <https://mpy.moodle.lecnam.net/course/view.php?id=2242#section-11>
- Télécharger FastFind : <https://github.com/DFIR-ORC/dfir-orc/releases/tag/v10.2.0>